📚 SALESFORCE ADMIN COURSE — EPISODE 31

Salesforce Security & Security Layers

Complete Foundation — Authentication vs. Authorization & The 4-Tier Security Model

- 🔐 Principle of Least Privilege
- 🔑 Authentication vs. Authorization
- 🌐 Layer 1: Organization Level
- 🗂️ Layer 2: Object Level (CRED)
- 🔒 Layer 3: Field-Level Security (FLS)
- 📋 Layer 4: Record-Level Security

EPISODE	DURATION	LEVEL	PILLAR
31 of Series	~25 Minutes	Core Foundation	Data Security

📋 Table of Contents

1	Introduction to Salesforce Security	0:00 – 1:30
2	Why is Security Important? (Least Privilege Principle)	1:30 – 3:30
3	Authentication vs. Authorization	3:30 – 5:30
4	The 4-Layer Salesforce Security Model (Architecture)	5:30 – 7:00
5	Layer 1: Organization-Level Security	7:00 – 8:30
6	Layer 2: Object-Level Security (CRED)	8:30 – 10:15
7	Layer 3: Field-Level Security (FLS)	10:15 – 12:00
8	Layer 4: Record-Level Security	12:00 – 14:00
9	How All 4 Layers Evaluate Access Together	14:00 – 16:30
10	Hands-on Practical Demo: Users, Employee__c & Salary	16:30 – 23:00

SECTION 1

🎬 Introduction to Salesforce Security

⏱ 0:00 – 1:30

Welcome back to the **Salesforce Admin Course!** Having completed Reports and Dashboards, we now begin the single most critical domain for any Salesforce Administrator: **Security**.

As a Salesforce Admin, your job isn't only building objects, flows, and reports. Your supreme responsibility is ensuring that **the right users have the right access to the right data at the right time**.

In a standard company, you will have Sales Reps, Sales Managers, Support Agents, and HR Managers. Should everyone see everything? **Absolutely not!** A sales rep must never view employee salaries, and HR doesn't need to see technical open pipeline deals.

SECTION 2 — CORE PRINCIPLE

🎯 The Principle of Least Privilege

⏱ 1:30 – 3:30

📌 GOLDEN SECURITY PHILOSOPHY

The **Principle of Least Privilege** states that users should be granted **only the minimum levels of access or permissions necessary** to perform their specific job responsibilities—and not an ounce more!

💡 OUR GOAL AS ADMINISTRATORS

Our philosophy is **NOT**: *"Block everyone from everything."*
Our goal is: **"Empower users with the exact access they need while safeguarding confidential company assets."**

SECTION 3 — CRITICAL DEFINITIONS

Authentication vs. Authorization

⏱ 3:30 – 5:30

Criterion	🔐 Authentication (AuthN)	🛡️ Authorization (AuthZ)
Core Question	**"Who are you?"**	**"What are you allowed to do?"**
Verification Method	Username, Password, Multi-Factor Authentication (MFA), SSO	Profiles, Permission Sets, OWD, Roles, Sharing Rules
Timing	Evaluated at the front door (Login screen)	Evaluated continuously as the user navigates records
Example	Proving you are *Rahul Sharma* using password + MFA	Deciding whether Rahul can *Edit* an Opportunity or see *Salary*

SECTION 4 — CORE ARCHITECTURE

The 4-Layer Salesforce Security Model

⏱ 5:30 – 14:00

Salesforce enforces data security through a cascading 4-layer funnel:

Layer 1: Organization-Level Security
Login Hours, IP Ranges, Passwords, MFA, Active Status
Can this user enter Salesforce?

Layer 2: Object-Level Security (CRED)
Create, Read, Edit, Delete permissions via Profiles & Permission Sets
Can they access this object?

Layer 3: Field-Level Security (FLS)
Visible vs. Read-Only on specific fields (e.g., Salary, SSN)
Can they see or edit this field?

Layer 4: Record-Level Security
OWD, Role Hierarchy, Sharing Rules, Manual Sharing, Teams
Which specific records can they access?

SECTION 5 — EVALUATION CHAIN

How All 4 Layers Evaluate Access Together

⏱ 14:00 – 16:30

⚠️ THE GOLDEN GATE RULE OF SALESFORCE SECURITY

Security evaluates from top to bottom. **If access is denied at an earlier layer, later layers CANNOT override or grant access back!**

SCENARIO A: BLOCKED AT OBJECT

Employee Object Blocked

If Rahul has **No Read Access** to the `Employee__c` object, sharing an individual employee record with him does **NOTHING**. He cannot view records of an object he cannot access!

SCENARIO B: BLOCKED AT FIELD

Salary Field Hidden

If Rahul owns the Employee record but `Salary__c` is hidden by Field-Level Security, Rahul can see the employee name and title, but the **Salary field remains 100% invisible**!

SECTION 6 — HANDS-ON PRACTICE

🧪 Practical Demo Scenario: 3 Users, Employee__c & Salary

⏱ 16:30 – 23:00

Step 1: Set Up 3 Distinct Users

- **Rahul Sharma:** Sales Executive (Standard User)
- **Amit Verma:** Sales Manager
- **Neha Gupta:** HR Manager

Step 2: Build the Custom Object: Employee__c

Create fields: *Department* (Picklist), *Designation* (Text), *Email* (Email), and **Salary** (Currency - Sensitive!).

Step 3: Test Object vs. Field-Level Security Live

1. **Object Level:** Strip `Employee__c` Read access from Rahul. Log in as Rahul → Employee tab is completely missing.
2. **Grant Object Access:** Grant Read access to `Employee__c`. Rahul can now see Employee records.
3. **Field Level (FLS):** Hide `Salary__c` from Rahul's profile, but grant visible access to Neha (HR).
4. **Verify as Rahul:** Opens record *Amit Verma* → Sees Department, Email, Designation. **Salary is completely invisible!**
5. **Verify as Neha:** Opens record *Amit Verma* → **Salary ₹1,20,000 is clearly visible!** 🎉

SECTION 7 — TROUBLESHOOTING

The "User Can't See Record" Diagnostic Framework

⏱ Real-World Admin Wisdom

🚨 NEVER BLAME THE PROFILE IMMEDIATELY!

When an end-user tickets: *"I can't see the ABC deal!"*, junior admins jump straight into Profiles. Experienced admins run the 4-layer diagnostic test:

- **1. Org Level:** Is the user active? Are they within Login Hours / trusted IPs?
- **2. Object Level:** Does their Profile or Permission Set have *Read* on the object?
- **3. Field Level:** Is the field enabled in FLS for their profile?
- **4. Record Level:** What is the OWD? Does the Role Hierarchy or a Sharing Rule grant access to this specific record?

🎯 Key Takeaways from Episode 31

01

Salesforce Security controls who enters the org, what actions they execute, what fields they see, and which records they open.

02

Authentication verifies *"Who are you?"* (MFA/login); **Authorization** dictates *"What are you allowed to do?"*

03

Organization-Level Security restricts login times, trusted IP address ranges, password complexity, and user activation.

04

Object-Level Security grants baseline CRED (Create, Read, Edit, Delete) capabilities on entire database tables.

05

Field-Level Security (FLS) controls visibility of specific columns (like Salary or SSN) even when object access is granted.

06

Record-Level Security determines which individual rows a user can open (via OWD, Roles, and Sharing Rules).

COMING UP NEXT — EPISODE 32

Organization-Level Security & Login Controls

Dive deep into Login Hours, IP Restrictions, Password Policies, and Multi-Factor Authentication (MFA)!

These notes are an official companion to the YouTube video. Practice hands-on in your Salesforce Developer Org!